Frank Henry

Module 6 Project: Microsoft 365

09/21/26

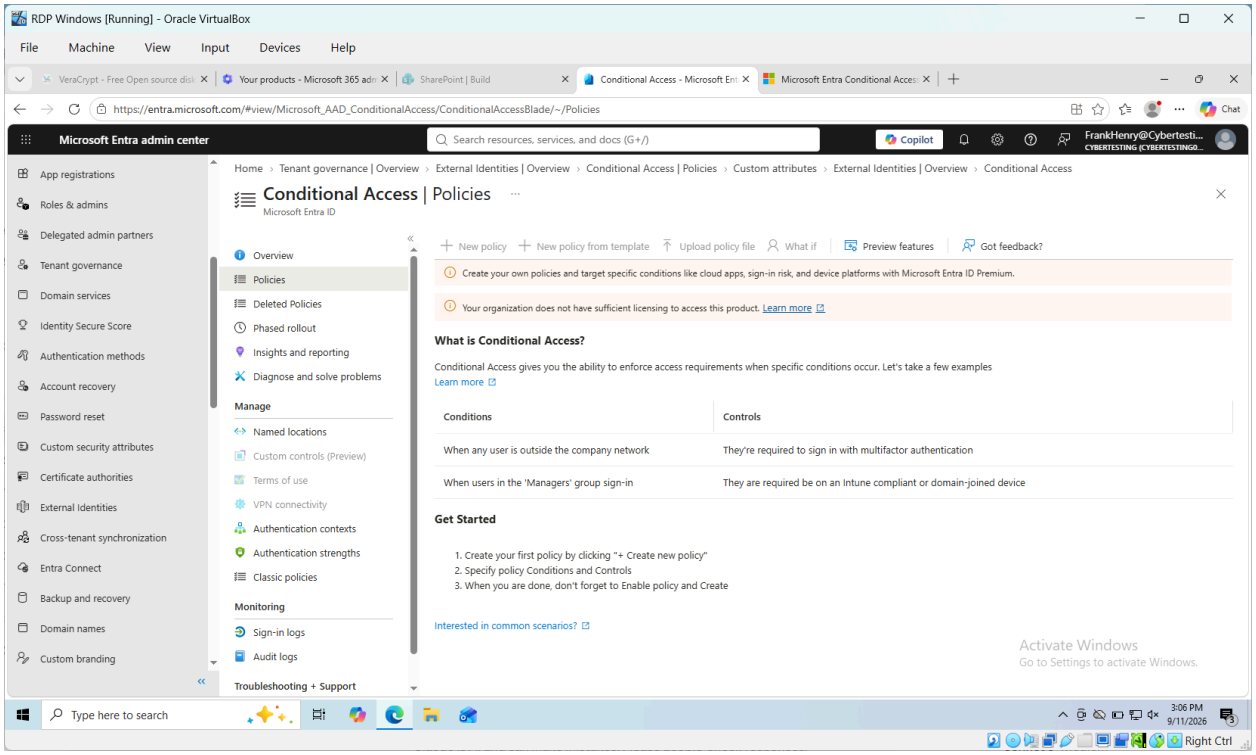
IAM Misconfiguration

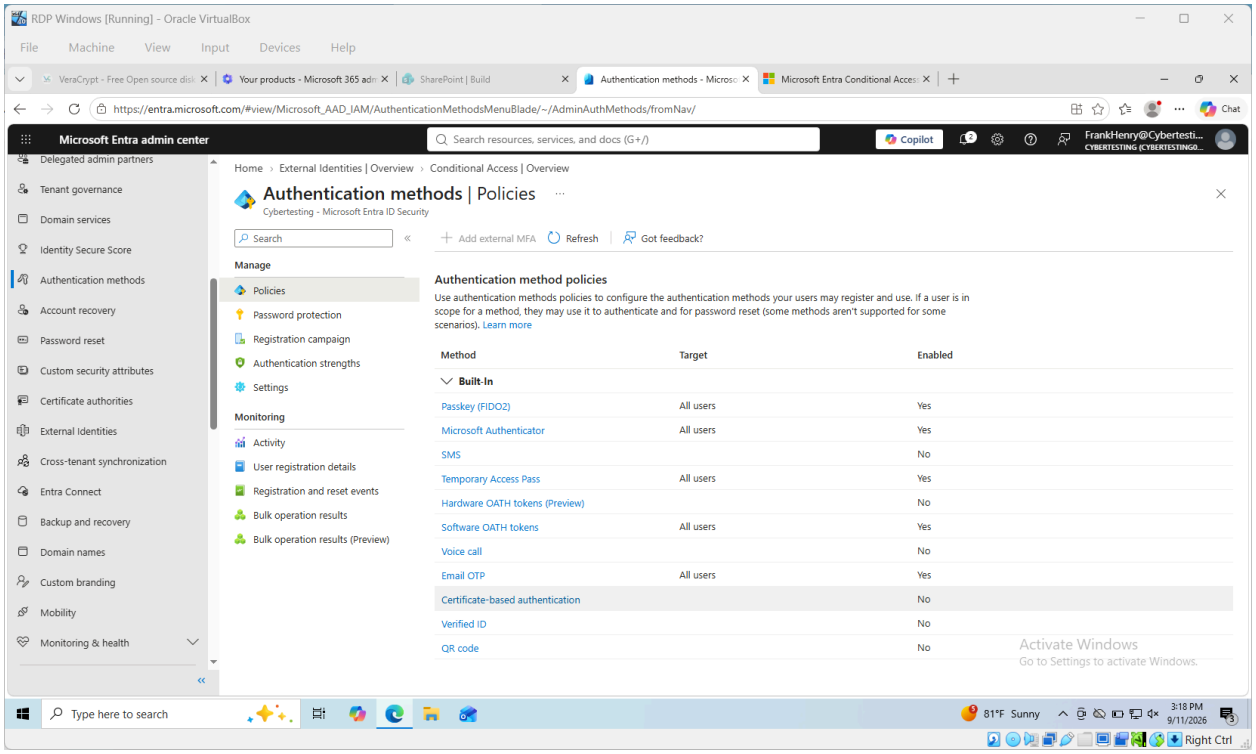
I've configured my Identity and Access controls for my company through Microsoft Entra. Some examples of what I did was removing the Global Administrator role from sales employee Alice Brown, but kept her as a User Administrator. I verified that myself is the only Global Administrator allowed.

I created some groups for employees. Example: Finance, Sales, IT, and HR groups. And placed the appropriate employees in those groups. We did this for least privilege so employees in certain departments only have access to the proper information needed to do their daily jobs.

Conditional Access Policies

Conditional Access Policies are security features. These features include requiring MFA for logins, or blocking risky countries from gaining access to any website credentials. During the assignment, we were to create a free account on Microsoft 365, and do not hold the required subscription to create conditional policies, unfortunately. But I was able to navigate to the section where the policies would be created.





Incident Response Plan

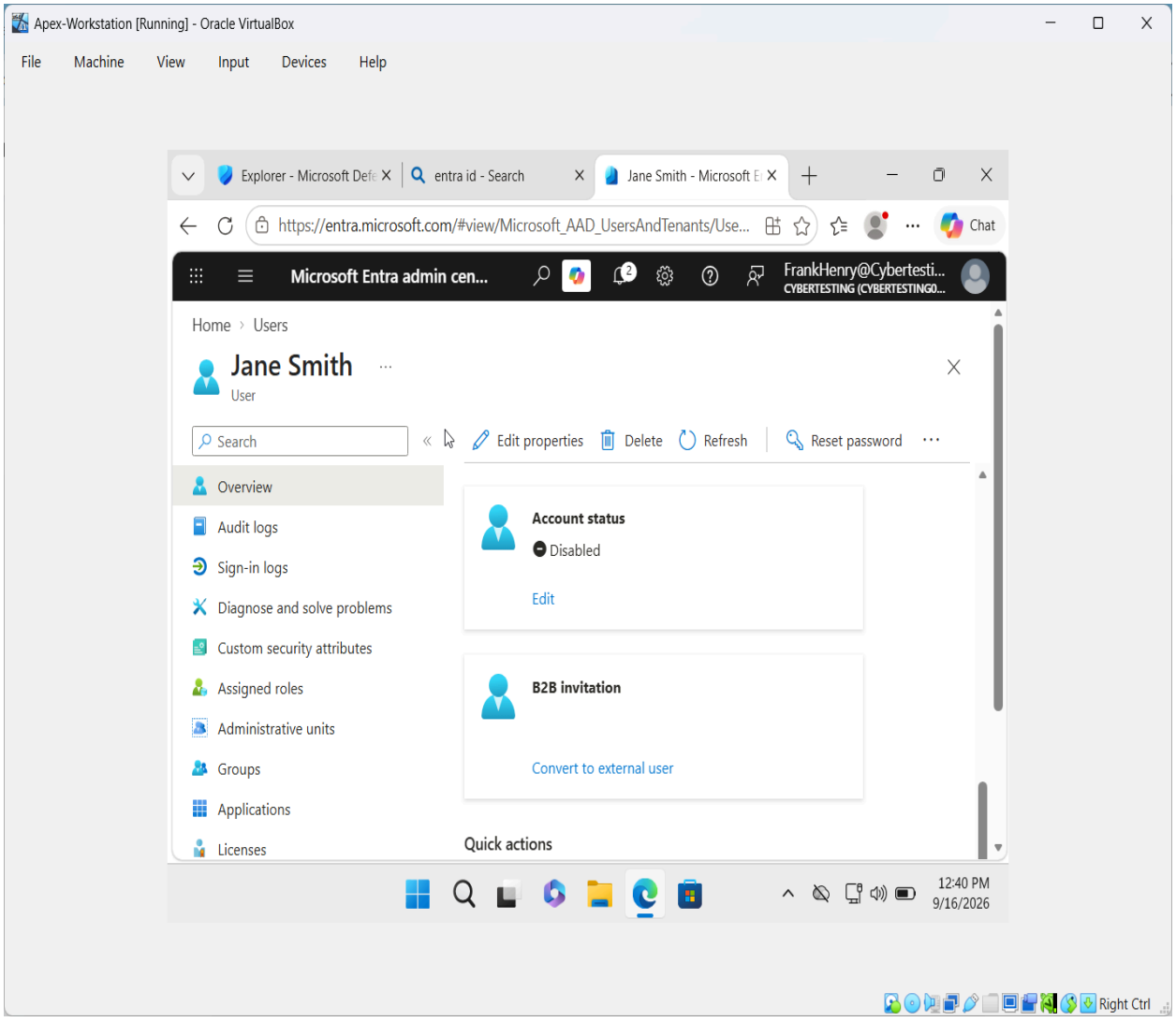
Six Stages

Stage	Goal	Application
Preparation	Build defenses before anything happens	We will train staff, keep backups available, conduct semi-annual code reviews
Identification	Detect and confirm an incident	We will use Splunk for SIEM alerts, conduct measures to prevent further action, and alert clients of any incidents that have occurred

Containment	Stop the spread immediately	We will immediately isolate the company's server which was contaminated, and revoke any contaminated employee credentials
Eradication	Remove the root cause	We will patch any known vulnerabilities, and wipe clean any detected malware
Recovery	Restore normal operations	We will restore any encrypted files, use backups for recovery, and redeploy once we know everything is safe to do so
Lessons Learned	Improve for next time	The incident commander will review where a vulnerability was found and take measures to prevent future incidents. Will also add a security review for sign-off

Phishing Incident Walkthrough

I checked mailboxes for all employees on Entra ID, and everything was clear. Unfortunately I am unable to simulate any phishing emails due to not having a paid subscription on Microsoft 365. What I was able to do was disable an employee's account in the case that a phishing attempt was successful. Example is shown below on the disable of employee Jane Smith's account.


Apex-Workstation [Running] - Oracle VirtualBox
File
Machine
View
Input
Devices
Help
Explorer - Microsoft Defe
entra id - Search
Jane Smith - Microsoft E
https://entra.microsoft.com/#view/Microsoft_AAD_UsersAndTenants/Use...
Chat
Microsoft Entra admin cen...
FrankHenry@Cybertesti...
CYBERTESTING (CYBERTESTINGO...
Home
Users
Jane Smith
User
Search
Edit properties
Delete
Refresh
Reset password
Overview
Audit logs
Sign-in logs
Diagnose and solve problems
Custom security attributes
Assigned roles
Administrative units
Groups
Applications
Licenses
Account status
Disabled
Edit
B2B invitation
Convert to external user
Quick actions
12:40 PM
9/16/2026
Right Ctrl

CIRT Roles

Role	Who's Assigned	Contact Method	Responsibility
Incident Commander	*Alice Brown (Security Manager)*	*Alice@Cybertesting038.onmicrosoft.com*	Authorizes all security measures taken and contacts company contact
SOC Analyst / Security Lead	*Anthony Edward*	Anthony@Cybertesting038.onmicrosoft.com	Detects alerts and prepares response plan
Forensic Specialist	*Tyler Guy*	Tyler@Cybertesting038.onmicrosoft.com	Pulls logs, confirms attack vector
IT Administrator	*Alice Brown (Security Manager)*	Alice@Cybertesting038.onmicrosoft.com	Disconnects server, restores backup
Legal & Compliance Officer	*Erin Folk*	*Erin*@Cybertesting038.onmicrosoft.com	Prepares legal report for client company, assessed liability
Communications Officer	*Todd Marsh*	*Todd*@Cybertesting038.onmicrosoft.com	Communicates everything with client